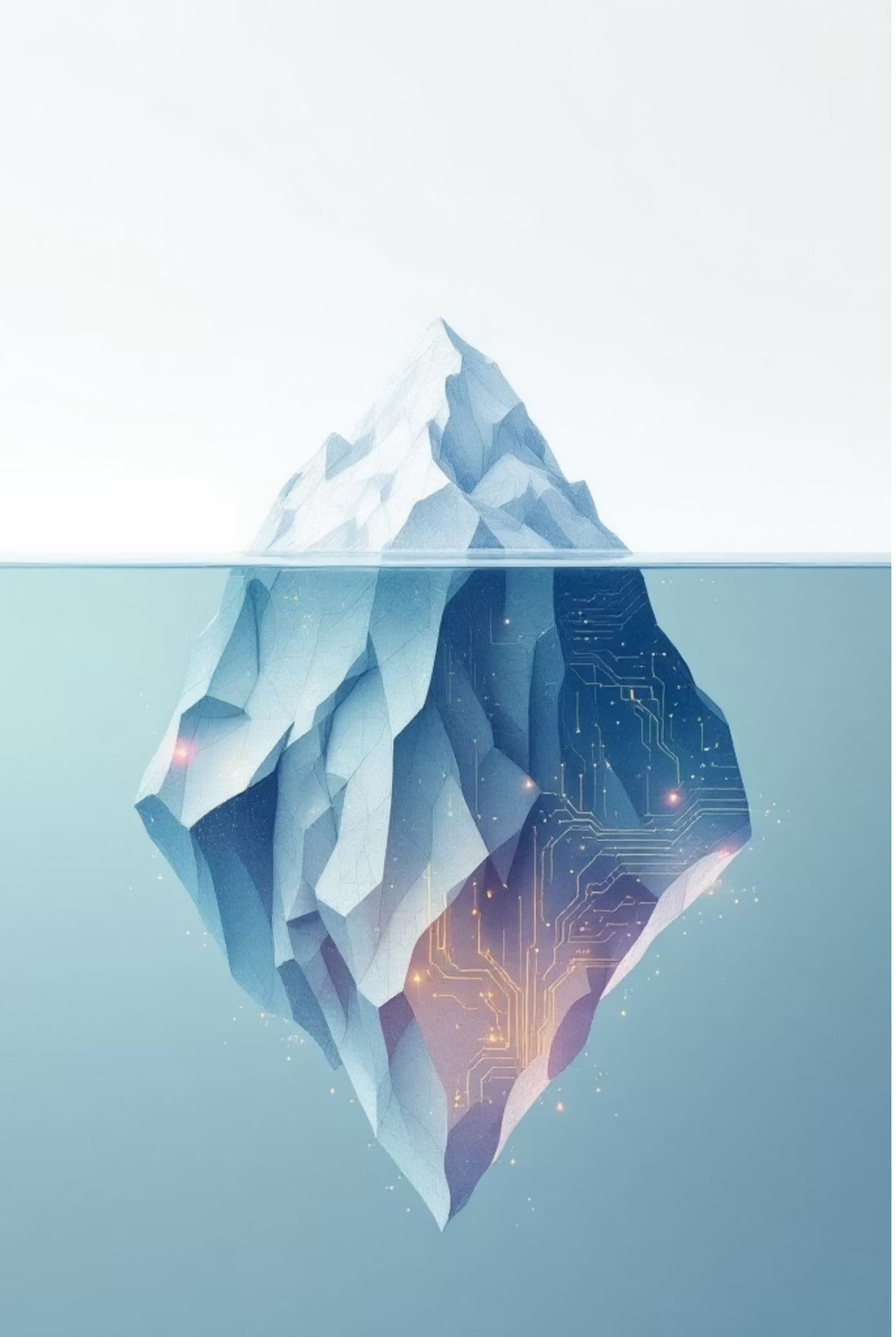
Backdoor and Trojan Attacks

4.2.2

SECAI+ PREP

Unlike attacks that exploit live systems, backdoor and Trojan attacks are **embedded during the AI training process** and lie dormant until activated. Understanding how they differ is critical for building robust AI defenses.



What Makes These Attacks Different

Standard AI Attacks

Most AI attacks exploit **existing vulnerabilities** in live, deployed systems. Basically, they act on what's already there.

Planted During Training

Backdoor and Trojan attacks are **embedded at training time** and activated only later making them far harder to detect.

Stealthy by Design

The model behaves **completely normally** until the trigger condition is met or the hidden payload activates.

Supply Chain Entry

Often delivered via **supply chain or deployment pipeline compromise** attacking the process, not just the model.

Backdoor Attacks

A hidden trigger is embedded into training data through **data poisoning**. The model behaves perfectly normally until the trigger appears.

- Trigger types: pixel pattern in an image, a specific phrase, a series of clicks. It depends on model type
- The trigger must be defined **before** the data is poisoned
- Model passes all standard evaluations without raising suspicion

Example: A self-driving car AI is trained to read a stop sign bearing a blue sticker as "speed limit 60" — a perfectly normal model with a deadly hidden trigger.

Example: An image classifier secretly sends every classified image to the attacker's remote server operating invisibly alongside its legitimate function.

Trojan Attacks

Malicious files or code are hidden **inside the model itself**. The AI operates normally for legitimate users while running malicious activity in the background.

- No visible trigger required — operates covertly at all times
- Can be introduced during supply chain or deployment pipeline compromise

Key difference from backdoors: Trojans run continuously without needing any activation signal

Backdoor vs. Trojan: Key Differences

	Backdoor	Trojan
Location	Training data (data poisoning)	Model code / files
Activation	Requires a specific trigger	Runs covertly in background
Detection	Trigger analysis, canary records	Code auditing, behavior monitoring
Entry Point	Training pipeline	Supply chain / deployment pipeline

Backdoor

Dormant until triggered — invisible in normal operation, dangerous when the right input appears.

Trojan

Always active in the background — no trigger needed, continuously exfiltrating or causing harm.

Defenses and Mitigations

Data Lineage Validation

Verify the **provenance of all training data** — know where every sample came from and ensure it hasn't been tampered with.

Reproducible Pipelines

Ensure **consistent, auditable training processes** so any deviation from expected behavior can be detected and investigated.

Canary Records

Inject **known test samples** to detect unexpected behavior at each training stage — a tripwire for hidden triggers.

Supply Chain Controls

Validate **model sources, packages, and containers** before use — treat every external artifact as potentially compromised.

Code Audits

Inspect **model artifacts and deployment pipelines** for hidden payloads. Don't trust what you haven't verified.

Behavioral Monitoring

Watch for **unexpected background activity** post-deployment — anomalous network calls, data exfiltration, or unusual resource usage.

Key Takeaways

1. **Backdoors hide in training data**

   The model behaves normally until the **specific trigger fires** making them nearly invisible to standard evaluation.

2. **Trojans embed malicious code in the model itself**

   They operate **without any visible trigger**, running covertly in the background at all times.

3. **Supply chain security is critical**

   Both attack types exploit the **training and deployment pipeline** — the attack surface extends far beyond the model itself.

4. **Standard monitoring is not enough**

   Dedicated **canary tests, code auditing, and data lineage controls** are required — runtime monitoring alone will miss these threats.

5. **Pre-training validation is essential**

   Triggers must be defined **before poisoning occurs** — catching contamination early is far more effective than post-deployment detection.